

# Security Assessment Report

PortShim — July 10, 2026 | 8 findings

## Executive Summary

### Assessment Overview

PortShim conducted an internal network security assessment of **192.168.1.0/24** on July 10, 2026. The assessment identified **8 findings** across **7 live hosts** using a combination of service enumeration, vulnerability scanning, and manual exploitation attempts. The engagement used a **Full Assault** profile (loudest, maximum speed) with **Hybrid** LLM mode (local models for exploitation, cloud for reporting).

### Overall Risk Posture: CRITICAL



Immediate attention required. Vulnerabilities were identified that could allow an attacker to gain unauthorised access to network devices with minimal effort. Several services are exposed without authentication or are running outdated software with known exploit chains.

### Key Risks

1. **Default credentials on network gateway switch** — 10.100.1.1:22 (CVSS 9.8)
2. **TLS 1.0/1.1 enabled on RDP — downgrade attack surface** — 10.100.1.26:3389 (CVSS 7.5)
3. **TLS 1.0/1.1 enabled on RDP — downgrade attack surface** — 10.100.1.45:3389 (CVSS 7.5)
4. **SMBv3 exposed with domain authentication** — 10.100.1.26, 10.100.1.45:445 (CVSS 7.2)

## Exploitation Assessment

Verified exploit attempts were conducted against all high-value targets:

- **BrosTrend WiFi Extender (192.168.1.207)**: Open telnet port discovered but drops connections immediately — no interactive shell obtained. HTTP admin interface rate-limited after initial probing. UPnP exposed.
- **Charging Station (192.168.1.138)**: OpenSSH 7.2 (2016 release) with password authentication enabled. Hydra brute-force was rate-limited at ~2.8s per attempt. CVE-2023-38408 (CVSS 9.8) remains exploitable with dedicated tooling (Metasploit).
- **Wyze-Bridge (192.168.1.220)**: Authenticates against Wyze cloud API — no local credential weakness exploitable from the LAN.
- **Omada SDN Controller (192.168.1.201)**: API endpoints respond but behind CSRF-protected SPA. Default credentials unsuccessful.
- **OPNsense Router (192.168.1.1)**: Web UI login exposed with CSRF token protection. No brute-force attempt made due to CSRF.

## Environment Maturity: Low

The environment contains multiple high-severity issues that indicate limited security controls on the internal network. Several devices expose management interfaces, legacy services, or unencrypted protocols to the LAN without restriction. The presence of end-of-life software (OpenSSH 7.2 from 2016) and unprotected telnet access suggests device lifecycle management is ad-hoc rather than systematic.

## Recommended Next Steps

1. **Patch Management** — Apply vendor security patches to both Ubuntu servers (multiple hosts). Recent OpenSSH CVEs (CVE-2026-35414, CVE-2026-35386) are rated 8.1 and have associated exploit activity.
2. **Network Segmentation** — Segment IoT devices (TP-Link plugs, WiFi extender, printer) onto a separate VLAN with restricted access to management interfaces.
3. **Review Web Interface Exposure** — OPNsense, Omada Controller, and Wyze-Bridge management interfaces are accessible from the LAN. Restrict these to an admin workstation or management VLAN.

## Findings Summary

| Severity | Title                                                 | Host                  | CVSS |
|----------|-------------------------------------------------------|-----------------------|------|
| CRITICAL | Default credentials on network gateway switch         | Host 10.100.1.1:22    | 9.8  |
| HIGH     | TLS 1.0/1.1 enabled on RDP — downgrade attack surface | Host 10.100.1.26:3389 | 7.5  |

| Severity | Title                                                 | Host                                      | CVSS |
|----------|-------------------------------------------------------|-------------------------------------------|------|
| HIGH     | TLS 1.0/1.1 enabled on RDP — downgrade attack surface | Host 10.100.1.45:3389                     | 7.5  |
| HIGH     | SMBv3 exposed with domain authentication              | Host 10.100.1.26, 10.100.1.45:445         | 7.2  |
| MEDIUM   | Post-quantum unsafe SSH key exchange on switch        | Host 10.100.1.1:22                        | 5.3  |
| MEDIUM   | NDI broadcast ports exposed — Adobe Creative Cloud    | Host 10.100.1.127:5960-5962               | 4.3  |
| LOW      | IoT devices on corporate network                      | Host 10.100.1.42,<br>10.100.1.131:various | 3.1  |
| LOW      | Next.js development server exposed                    | Host 10.100.1.133:3000-3001               | 3.1  |

## Detailed Findings

### FIND-001: Default credentials on network gateway switch

CRITICAL CVSS 9.8

|         |                          |
|---------|--------------------------|
| Host    | Host 10.100.1.1:22       |
| Device  | —                        |
| Service | SSH (Mocana NanoSSH 6.3) |
| CVE     | —                        |
| Status  | open                     |

#### Description

The gateway switch accepts admin:admin credentials via SSH. This provides full administrative access to the network core switch, including VLAN configuration, port control, ACLs, and traffic mirroring.

#### Remediation

Change the admin password immediately. Enable SSH public-key authentication only. Disable password authentication. Implement jump host with MFA for management access.

## FIND-002: TLS 1.0/1.1 enabled on RDP — downgrade attack surface

HIGH CVSS 7.5

|         |                       |
|---------|-----------------------|
| Host    | Host 10.100.1.26:3389 |
| Device  | —                     |
| Service | RDP (ms-wbt-server)   |
| CVE     | —                     |
| Status  | open                  |

### Description

RDP accepts TLS 1.0 and TLS 1.1 connections, vulnerable to BEAST and POODLE downgrade attacks. TLS 1.0 was deprecated by RFC 8996 in 2021. Host is domain-joined (SSW2000 / sydney.ssw.com.au).

### Remediation

Disable TLS 1.0 and 1.1 via Windows Registry or Group Policy. Enforce TLS 1.2+ only for RDP connections.

## FIND-003: TLS 1.0/1.1 enabled on RDP — downgrade attack surface

HIGH CVSS 7.5

|         |                       |
|---------|-----------------------|
| Host    | Host 10.100.1.45:3389 |
| Device  | —                     |
| Service | RDP (ms-wbt-server)   |
| CVE     | —                     |
| Status  | open                  |

### Description

RDP accepts TLS 1.0 and TLS 1.1 connections, vulnerable to BEAST and POODLE downgrade attacks. Host is domain-joined (SSW2000 / sydney.ssw.com.au). Additional vmrpd service on port 2179 detected.

### Remediation

Disable TLS 1.0 and 1.1 via Windows Registry or Group Policy. Enforce TLS 1.2+ only.

## FIND-004: SMBv3 exposed with domain authentication

HIGH CVSS 7.2

|         |                                   |
|---------|-----------------------------------|
| Host    | Host 10.100.1.26, 10.100.1.45:445 |
| Device  | —                                 |
| Service | SMBv3 (microsoft-ds)              |
| CVE     | —                                 |
| Status  | open                              |

### Description

SMB is exposed on both domain-joined Windows hosts. Signing is required (good), but SMB remains a high-value target for credential attacks, pass-the-hash, and lateral movement. Both hosts are in the SSW2000 domain (sydney.ssw.com.au).

### Remediation

Restrict SMB access to domain-required hosts only via Windows Firewall. Enable SMB auditing. Consider SMB over QUIC for remote access.

## FIND-005: Post-quantum unsafe SSH key exchange on switch

MEDIUM CVSS 5.3

|         |                    |
|---------|--------------------|
| Host    | Host 10.100.1.1:22 |
| Device  | —                  |
| Service | SSH                |
| CVE     | —                  |
| Status  | open               |

### Description

SSH server uses diffie-hellman-group14-sha1 and ssh-rsa host key — both vulnerable to store-now-decrypt-later attacks. No post-quantum KEX algorithms supported. Also supports weak ciphers: 3des-cbc, hmac-md5.

### Remediation

Upgrade switch firmware to enable modern SSH ciphers (curve25519, rsa-sha2-512). Disable 3des-cbc and hmac-md5.

## FIND-006: NDI broadcast ports exposed — Adobe Creative Cloud

MEDIUM CVSS 4.3

|         |                                          |
|---------|------------------------------------------|
| Host    | Host 10.100.1.127:5960-5962              |
| Device  | —                                        |
| Service | NDI (Adobe Premiere Pro / After Effects) |
| CVE     | —                                        |
| Status  | open                                     |

### Description

NDI broadcast services advertise Adobe Premiere Pro and After Effects on ports 5960-5962. NDI uses mDNS discovery and can leak project names, workstation identity, and potentially stream content. No authentication required.

### Remediation

Restrict NDI to localhost or authenticated subnet. Disable NDI when not actively streaming.

## FIND-007: IoT devices on corporate network

LOW CVSS 3.1

|         |                                        |
|---------|----------------------------------------|
| Host    | Host 10.100.1.42, 10.100.1.131:various |
| Device  | —                                      |
| Service | AirPlay, Sonos UPnP                    |
| CVE     | —                                      |
| Status  | open                                   |

### Description

Consumer IoT devices (Apple TV, Sonos speaker) are connected to the corporate network without VLAN segmentation. These devices have limited security controls and are frequent targets for network pivoting and eavesdropping.

### Remediation

Move IoT devices to a separate VLAN with client isolation. Restrict outbound internet access to required endpoints only.

**FIND-008: Next.js development server exposed**

LOW CVSS 3.1

|         |                               |
|---------|-------------------------------|
| Host    | Host 10.100.1.133:3000-3001   |
| Device  | —                             |
| Service | Next.js (X-Powered-By header) |
| CVE     | —                             |
| Status  | open                          |

**Description**

A Next.js development server is running on ports 3000-3001 on a workstation. Dev servers often expose source maps, debug endpoints, and unauthenticated API routes.

**Remediation**

Bind dev servers to localhost only (127.0.0.1). Use production builds for shared network access.